

Week 1 Notes

What is Ethical Hacking

Definition: using tactics, techniques, and procedures commonly used by attackers in order to locate weaknesses so they can be remediated (fixed).

In practice: using a defined methodology of:

1. Reconnaissance
2. Scanning
3. Enumeration
4. Exploitation
5. Analysis

...to increase the overall security posture of an organization with targeted recommendations.

 **Keep in mind Almost everything you will be doing is probably illegal in at least one jurisdiction — this is why scope and authorization matter so much (see [Get Out of Jail Free Card](#)).**

Ethical Hacking vs. Related Disciplines

Discipline	Description
Penetration testing	Usually a tightly scoped, point-in-time assessment of a section of an organization's network
Red teaming	Less tightly scoped; usually carte blanche (within reason) attacks against a target network
Application testing	A limited version of ethical hacking focused exclusively on an application — commonly a web application

Why Ethical Hacking

Real-world headlines illustrate why organizations need ethical hackers:

- Hacking groups targeting organizations focused on North Korea's missile program
- Ransomware hackers hitting nearly two dozen Texas cities

- US Cyber Command publicly posting malware linked to a North Korean hacking group
- Election machine keys found exposed on the internet

Takeaway: threats are real, active, and often target critical/public infrastructure — ethical hacking helps organizations find and fix weaknesses before malicious actors exploit them.

The Importance of Ethics

Definition: moral principles that govern a person's behavior or the conducting of an activity.

🔥 **tl;dr Do no harm.**

Key principles

- You're being employed to help improve a security posture
 - Keep the needs/goals of your employer in mind
 - **Do no harm** — though this can't always be helped
 - **Revision:** do no *deliberate* harm, and own up when something goes awry
-

Get Out of Jail Free Card

How to protect yourself while doing this work:

- **Documentation will save you if you are clear**
 - Always scope the engagement up front
 - Be clear and comprehensive
 - Define your methodology at a high level and provide it
 - **Communicate, communicate, communicate**
 - Make sure the employing company is informed about your actions when they need to be (depending on the scope and agreements up front)
 - **Secrecy is bad** unless you've agreed to it ahead of time
-

A Code of Ethics

- Many professional security certifications require you to adhere to a code of ethics
- Know the code of ethics you are expected to comply with

- Understand all laws and regulations that apply to you and the organization you're working for
-

Summary

- Ethical hacking is an important skill, but it must be taken seriously
 - Ethical hacking, penetration testing, red-teaming, and application testing are related but **not the same**
 - **Do no harm** — at least do no *deliberate* harm
 - Get a [Get Out of Jail Free Card](#) by ensuring the scope of your engagement is completely clear up front and agreed to by a business owner — someone with the authority to authorize the testing
-

My Notes

Week 1: Ethics — Key Points

- **Ethical hacking** = using attacker tactics/techniques to find weaknesses so they can be fixed (recon → scan → enumerate → exploit → analyze)
- Almost everything you do is probably **illegal in some jurisdiction** → authorization is critical
- **Pentesting** = narrow scope, point-in-time
- **Red teaming** = broad scope, more freedom
- **App testing** = focused on one application
- Why it matters: real attacks hit real targets (ransomware on cities, nation-state hacking groups, exposed election systems)
- **Ethics** = moral principles guiding behavior → tl;dr: **do no harm**
- Do no *deliberate* harm, and own up if something goes wrong anyway
- **Stay protected**: clear scope + documentation, constant communication, keep employer informed, no unplanned secrecy
- Follow the **code of ethics** for your certification + know the laws that apply to you and your client
- **Bottom line**: get everything scoped and signed off by someone with real authority *before* you start